Pickle Rick — TryHackMe (Fácil)

Plataforma: TryHackMe · **Categoría:** Reconocimiento web / Análisis de código fuente / Command Injection / PrivEsc · **Herramientas:** Nmap, Gobuster, curl, CyberChef, navegador web

---

Resumen

Máquina Linux temática de Rick and Morty con foco completamente web. Las credenciales de acceso están expuestas en el código fuente de la página principal y en `robots.txt`. Con ellas se accede a un panel de administración con ejecución remota de comandos (RCE), que permite explorar el sistema de archivos y encontrar los tres ingredientes ocultos. El usuario del servidor web tiene permisos de sudo irrestrictos, lo que convierte cualquier exploración en acceso root de facto.

Habilidades demostradas

- Escaneo de puertos y detección de servicios con Nmap (`-sC -sV`)
- Enumeración de directorios web con Gobuster
- Análisis de código fuente HTML para extraer credenciales expuestas en comentarios
- Lectura de `robots.txt` como fuente de información sensible
- Identificación y explotación de Command Injection / RCE en panel web
- Evasión de filtros de lista negra usando comandos alternativos (`less`, `tac`, `grep`)
- Escalada de privilegios mediante `sudo (ALL) NOPASSWD: ALL`
- Reconocimiento de rabbit holes (distractores intencionales) en CTFs

---

1. Reconocimiento

```
nmap -sC -sV <IP>
```

```
❯ nmap -sC -sV 10.66.156.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-17 17:35 -03
Nmap scan report for 10.66.156.3
Host is up (0.13s latency).
Not shown: 995 closed tcp ports (conn-refused)
PORT      STATE    SERVICE         VERSION
22/tcp    open     ssh             OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; p
rotocol 2.0)
| ssh-hostkey:
|   3072 33:1b:04:86:f5:1b:07:1c:b5:83:79:f5:89:68:56:3c (RSA)
|   256 64:7c:bd:6c:0c:0e:8a:e2:fb:bc:67:f1:6c:53:92:2d (ECDSA)
|_  256 61:57:ea:a7:51:b0:26:41:1a:6e:30:d5:f1:84:38:bd (ED25519)
80/tcp    open     http            Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Rick is sup4r cool
|_http-server-header: Apache/2.4.41 (Ubuntu)
1009/tcp  filtered unknown
1138/tcp  filtered encrypted_admin
44443/tcp filtered coldfusion-auth
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org
/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.38 seconds
```

Puerto	Servicio	Versión
22	SSH	OpenSSH 8.2p1 Ubuntu
80	HTTP	Apache 2.4.41 (Ubuntu)

El título HTTP `Rick is sup4r cool` es una pista temática. El servidor SSH rechaza autenticación por contraseña (`Permission denied (publickey)`), por lo que el vector principal es el servicio web en el puerto 80.

---

2. Enumeración web

Código fuente de la página principal

La página principal mostraba un mensaje narrativo sin información técnica visible. El código fuente (`Ctrl+U`) contenía un comentario HTML con una credencial:

```
<!-- Note to self, remember username! Username: R1ckRul3s -->
```

Los comentarios HTML son completamente invisibles en el navegador pero visibles para cualquiera que inspeccione el código fuente. Práctica de seguridad deficiente muy común en aplicaciones web mal desarrolladas.

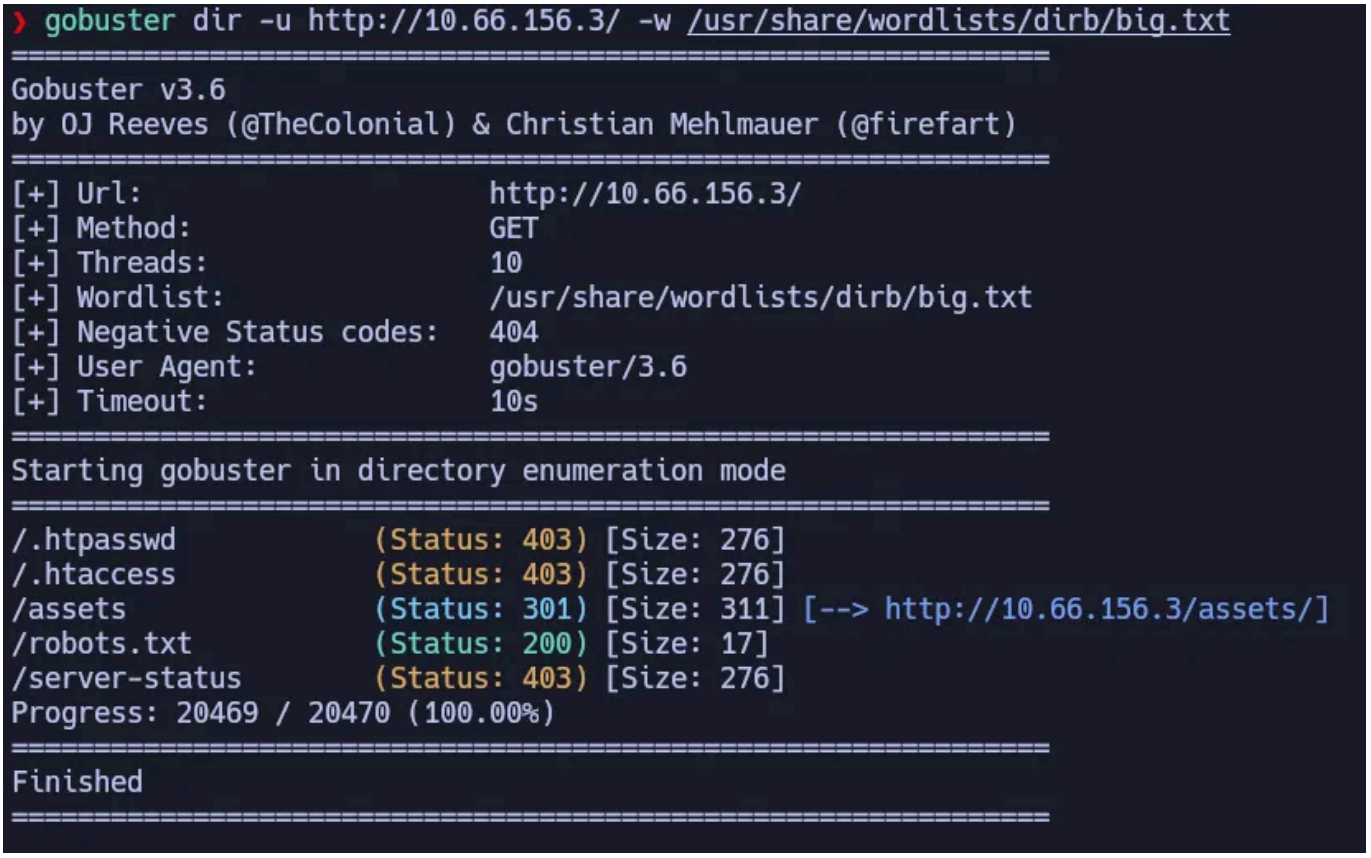
robots.txt

```
curl -s http://<IP>/robots.txt
```

El archivo contenía una sola palabra que resultó ser la contraseña del panel de administración. `robots.txt` es un archivo público — cualquier dato incluido ahí es accesible para cualquier visitante, no solo para buscadores.

Gobuster

```
gobuster dir -u http://<IP>/ -w /usr/share/wordlists/dirb/big.txt
```



Gobuster encontró `/assets` y `/robots.txt`, pero **no encontró `login.php` ni `portal.php`**. Esto confirma que Gobuster depende completamente de la wordlist — rutas con nombres específicos del contexto no aparecen en listas genéricas. Fueron descubiertas probando rutas comunes manualmente en el navegador.

---

3. Acceso al panel de comandos

Con las credenciales obtenidas:

- **Usuario:** `R1ckRul3s` (del comentario HTML)
- **Contraseña:** (de `robots.txt`)

Acceso a `http://<IP>/login.php`, que redirige a `http://<IP>/portal.php` tras autenticarse.

El portal expone un **Command Panel**: un campo de texto con un botón "Execute" que envía comandos al servidor vía POST y muestra el resultado en la página. Esto es RCE directa — cualquier comando Linux válido se ejecuta en el servidor con los permisos del proceso web (`www-data`).

Verificación del nivel de acceso

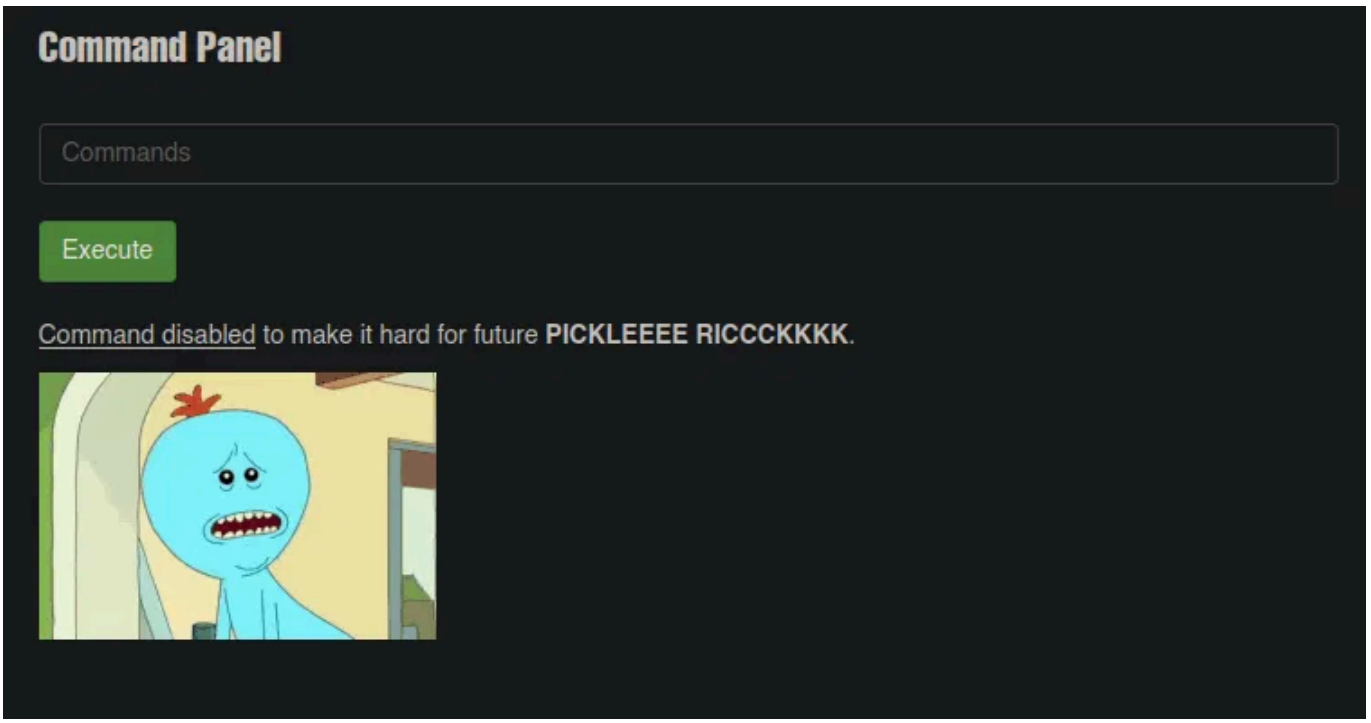
```
sudo -l
```

Resultado: `(ALL) NOPASSWD: ALL`

`www-data` puede ejecutar **cualquier comando como cualquier usuario**, incluyendo root, sin contraseña. Es la configuración de sudo más permisiva posible.

Comandos bloqueados

El panel tiene una lista negra que bloquea ciertos comandos, incluyendo `cat`:



Los filtros de lista negra son inherentemente eludibles porque es imposible bloquear todos los comandos equivalentes. Alternativas funcionales:

```
less <archivo>
tac <archivo>
grep . <archivo>
```

---

4. Ingrediente 1

```
ls
```



Se encontró `Sup3rS3cretPickl3Ingred.txt` en el directorio raíz del servidor web. Lectura con alternativa a `cat`:

```
less Sup3rS3cretPickl3Ingred.txt
```

También se encontró `clue.txt`, cuyo contenido indicaba buscar en el sistema de archivos para los ingredientes restantes.

---

5. Ingrediente 2

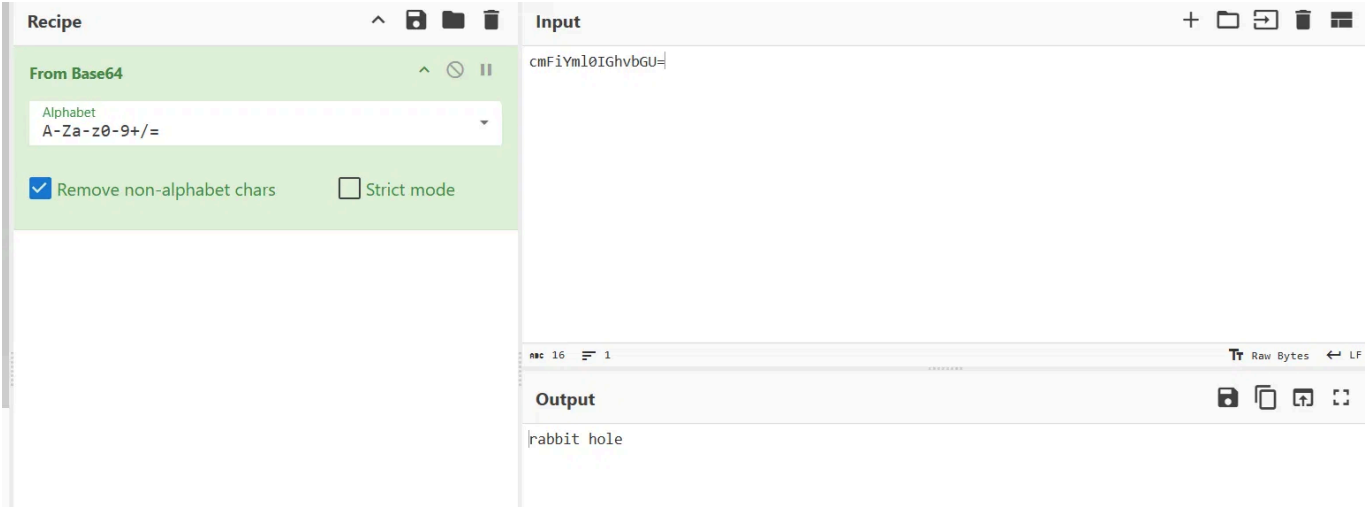
```
sudo find / -name "*ingredient*" 2>/dev/null
```

Se encontró el archivo `/home/rick/second ingredients` (nombre con espacio incluido). Las comillas son necesarias para que la shell lo interprete como un único argumento:

```
sudo less "/home/rick/second ingredients"
```

Distractor: rabbit hole en el código fuente del portal

El código fuente de `portal.php` contenía un comentario con una cadena codificada en base64. Tras decodificarla **7 veces** consecutivas en CyberChef:



El resultado fue `rabbit hole` — pista intencional del creador de la sala indicando que ese camino era un distractor. Técnica común en CTFs para consumir tiempo del atacante.

---

6. Ingrediente 3

El tercer ingrediente estaba en la carpeta de root, accesible gracias a los permisos de sudo irrestrictos:

```
sudo ls /root
sudo less /root/3rd.txt
```

Lo que probé y no funcionó

- **SSH con las credenciales del comentario HTML**: el servidor rechaza autenticación por contraseña (`Permission denied (publickey)`). SSH estaba activo pero no era el vector.
- **Gobuster para encontrar login.php y portal.php**: ninguna de las dos wordlists (`common.txt`, `big.txt`) encontró las páginas PHP relevantes. Rutas con nombres específicos del contexto no aparecen en listas genéricas.
- **Rabbit hole de base64**: el comentario en `portal.php` con cadena base64 parecía una pista. Decodificar 7 veces en CyberChef devolvió `rabbit hole` — distractor intencional.

Impacto

Un atacante sin credenciales puede comprometer el servidor completo desde la red leyendo únicamente el código fuente HTML y `robots.txt`. Ambas fuentes son accesibles públicamente sin autenticación. Desde el panel RCE, `www-data` tiene sudo ilimitado, lo que equivale a root inmediato. No se necesita ninguna CVE, exploit ni código personalizado.

Perspectiva defensiva

- **Nunca incluir credenciales en comentarios HTML ni en `robots.txt`**: ambos son archivos públicos. Un comentario HTML invisible en el navegador es visible para cualquier visitante que revise el código

fuente.
- **No implementar paneles de ejecución de comandos del sistema en aplicaciones web**: si es absolutamente necesario, usar listas blancas estrictas de comandos permitidos, nunca listas negras.
- `sudo (ALL) NOPASSWD: ALL` **es la configuración más peligrosa posible**: equivale a dar acceso root completo sin autenticación a cualquier proceso que corra con ese usuario. Aplicar principio de mínimo privilegio.
- **Proteger paneles de administración con autenticación multifactor** y no exponerlos en rutas predecibles.

Lecciones aprendidas

- El código fuente HTML y `robots.txt` son las primeras cosas a revisar en cualquier servidor web — revelan información que el navegador oculta visualmente.
- Gobuster no es exhaustivo: solo encuentra rutas que están en su wordlist. Rutas con nombres específicos del contexto requieren exploración manual.
- Los filtros de lista negra son un control de seguridad débil. `less`, `tac` y `grep .` son equivalentes funcionales de `cat` que evitan filtros simples.
- Reconocer un rabbit hole a tiempo ahorra esfuerzo: si una pista parece demasiado elaborada sin resultados concretos, considerar que sea intencional.
- `sudo (ALL) NOPASSWD: ALL` en un usuario de servidor web es acceso root inmediato para cualquier atacante que comprometa ese proceso.

Referencias

- TryHackMe — Pickle Rick
- OWASP — Command Injection
- GTFOBins